# LLM □□ Windows □□□□□□ □□ □□ □ □ □□

## □□□□□ · □□ □□ · Subagent □□ □□□ □□

Windows □ □□ □□□ □□ □□·□□ □□ □□□□□ □□□□ □□ Slidev □□

□□□: 2026-04-24 · □□: Windows □ □□ □□, LLM □□□□ □□, MCP □□ □□

# 1. □□ □□

# Windows □ □□ □□□ □□

- □□ □□ □□□ □□
  - EXE / DLL / MSI / MSIX
  - □□□, scheduled task, COM, shell extension
  - installer / updater / helper process
- □□□ □□ □□□ □□□ □□
  - □□, □□□□□, □□□ □□, □□□□ □□□□
- LLM □□ □□□ □□□□ □□ □□□□ □□
- □□□□□□□□□□ □□ □□□ □□□□ □□□

# □□ □□

- □□□□ □□□ □□ □□
- □□□□□□ □□□ □□□□ □□
- Auditor□ □□ □□□□ □□ finding □□
- Reviewer□ Verifier□ □□□□□ □□
- Coordinator□ □□□ □□□ □□□ □□
- □□ □□□□□ Verified finding□ □□

# □□ □□ □□

LLM□ □□□□□□ □□ □□□ □□□, □□□, □□□, □□ □□□ □□□ □□□ □□□?

## □□□ □ □□

- □□ LLM□ □□ □□□ □□
- raw evidence □□ □□□ □□
- □□□□□□ □□ □□□ □□
- MCP□ □□□ □□ □□□ □□
- Reviewer □□ finding□ □□

## □□□ □□

- □□ □□ + □□□ □□
- skill □□ □□ □□
- □□ subagent □□
- deterministic tool□ 1□ □□□ □□
- Reviewer / Verifier □□□

# 2. □□ □□ □□

## □□ □□ □□

- □□ `AGENTS.md`
- `PLANS.md` / □□□□
- `docs/status`, `docs/evidence`, `docs/findings`, `docs/reports`
- □□ □□□ skills
- □□·□□□□ □□□ □□□□ subagents
- Reviewer / Verifier □□□
- read-only □□ MCP + allowlist
- GitHub Projects + sub-issues + dependencies
- Windows□ □□□□ □□ □□

## □ □□□ □□□□ □□

- LLM □□□□ □□ □□
- □□ □□ □□ □□ □□
- □□ □□□□ □□
- □□ □□□ □□□ □□
- false positive□ evidence gap □□
- MCP/tool misuse □□ □□
- □□□ □□ □□□ □□□ □□

# □□ 1: □□□ □□, □□□ □□□

### `AGENTS.md`

- □□ □□
- □□ □□
- □□□ □□
- subagent □□ □□
- □□ □□□ □□

### `docs/`

- □□□□ □□□
- □□□□
- □□□□□
- □□
- finding
- □□ □□
- □□□

□□ □□: `AGENTS.md`□□ □□□ □□□ □□, □□ □□ □□□ □□□ `docs/`□ source of truth□ □□□□□.

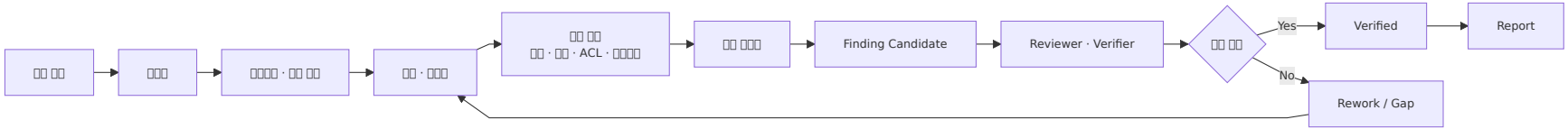
# □□ 2: Skill □□, Subagent□ □□□□□

| □□ | □□□ □□□ | □□ |
|---|---|---|
| Skill | □□ □□□ □□ | □□ bootstrap, □□□□□ □□, finding □□, evidence packaging |
| Subagent | □□·□□□ □□ | Static Auditor, ACL Auditor, Runtime Tracer, Reviewer, Verifier |
| MCP | □□ □□□ □□ | □□, □□□ □□, □□□□□, GitHub Projects, CodeQL □□ |
| Tool script | □□□□ □□ □□ | BinSkim, Sigcheck, AccessChk, Procmon, Autoruns |

Subagent □□ □□□ □□ □□□ □□ □□□ □□ □□□□□. □□ □□□ skill□ □□□□, □□□ □□ □□□ □□□ □□□□ subagent□ □□□□□.

# 3. □□ □□ □□

# □□ □□ □□

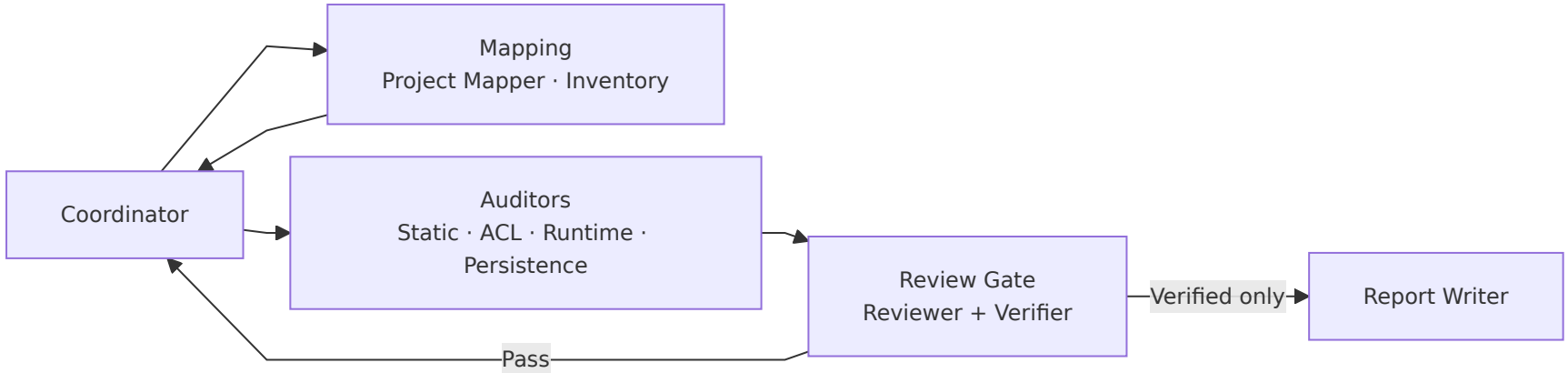

□□ □□
□□□
□□□□ · □□ □□
□□ · □□□
□□ □□
□□ · □□ · ACL · □□□□
□□ □□□
Finding Candidate
Reviewer · Verifier
□□ □□
Yes
Verified
Report
No
Rework / Gap

# □□ □□□ □□□

| □□ | □□ | □□ □□□ |
|---|---|---|
| □□□□ □□ □□ | Coordinator, Project Mapper | `docs/status/01_project_snapshot.md` |
| □□ □□□□ | Binary Inventory | `docs/evidence/<run-id>/normalized/inventory.csv` |
| □□□□ □□ | Coordinator, Project Mapper | `docs/scope/trust_boundaries.md` |
| □□ □□ | Coordinator | `docs/plans/active/*.md` |
| □□□□□ □□ | Auditors | raw evidence, normalized summary, finding candidate |
| □□ | Reviewer, Verifier | review note, verification result |
| □□ | Report Writer | weekly report, final report |

# 4. □□□□ □□ □□

# Coordinator □□ □□

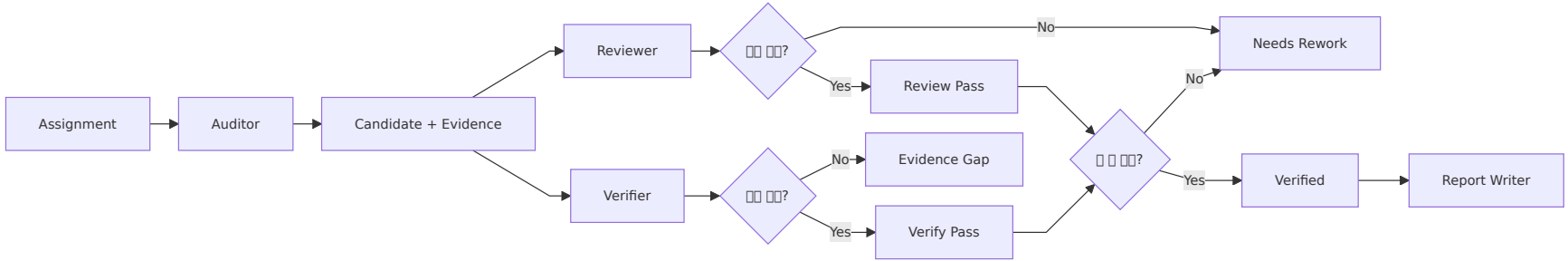


# □□ □□ □□

| | | |
|---|---|---|
| Agent | □□ | □□ □□·□□ |
| Coordinator | □□ □□, □□ □□, □□ □□, □□ □□ | □□ □□□ □□ □□ |
| Project Mapper | □□ □□, □□□□ □□ | finding □□ □□ |
| Binary Inventory | □□□□, □□□, □□ □□ | □□□ □□ □□ |
| Static Auditor | □□ □□□ □□ finding □□ | □□ □□ □□ |
| ACL Auditor | ACL/□□ □□ □□ | □□ □□□ □ □□ □□ |
| Runtime Tracer | □□, □□□□, □□ □□ | □□ □□ □□ |
| Persistence Auditor | □□ □□, □□, □□□□ □□ □□ | □□ □□ □□ □□ |

# 5. Reviewer / Verifier □□□

# □□ □□ □□


Assignment
Auditor
Candidate + Evidence
Reviewer
Verifier
□□ □□?
□□ □□?
No
Yes
No
Yes
Review Pass
Evidence Gap
Verify Pass
□ □ □□?
No
Yes
Needs Rework
Verified
Report Writer

# Reviewer□ Verifier□ □□□□ □□

## Reviewer

□□ □□:

- □□□ □□ □□
- □□ □□
- □□ □□□
- severity □□ □□
- remediation □□□

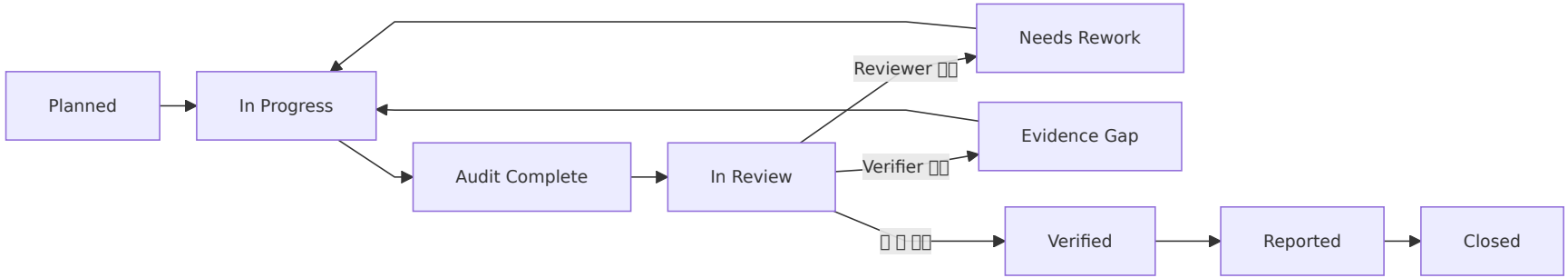
## Verifier

□□ □□:

- raw evidence □□ □□
- □□, □□, □□ □□ □□□
- □□ □□ □□□
- □□ □□□ □□ □□□
- □□/OS □□□□ □□ □□

□□: Reviewer□ Verifier□ □□ □□□ □□□ Verified Finding□□ □□□□□.

# □□ □□


Needs Rework
Reviewer □□
Planned
In Progress
Evidence Gap
Audit Complete
In Review
Verifier □□
□ □ □□
Verified
Reported
Closed

# 6. □□ □□□ □□ □□

# □□ □□ □□

```
repo/
├─ AGENTS.md
├─ PLANS.md
├─ .agents/
│  └─ skills/
├─ .codex/
│  └─ agents/
├─ docs/
│  ├─ status/
│  ├─ scope/
│  ├─ plans/
│  ├─ checklists/
│  ├─ evidence/
│  ├─ findings/
│  ├─ review/
│  └─ reports/
└─ tools/
   ├─ run_binskim.ps1
   ├─ run_sigcheck.ps1
   ├─ run_accesschk.ps1
   ├─ run_procmon_capture.ps1
   └─ run_autoruns_export.ps1
```

# □□□ □□ □□□ □□

| □□ | □□ | □□ |
|---|---|---|
| `docs/checklists/` | □□□ | Windows □ □□ □□ |
| `docs/plans/active/` | □□ □□ □□ | phase, owner, gate, stop condition |
| `docs/evidence/<run-id>/raw/` | □□ □□ | tool output, logs, screenshots |
| `docs/evidence/<run-id>/normalized/` | □□/□□□ | csv, json, summary |
| `docs/findings/` | □□ finding | `F-001-dll-search-path.md` |
| `docs/review/` | □□/□□ □□ | reviewer note, verifier note |
| GitHub Issues/Projects | □□ □□ | assignee, status, blocker, dependency |

# GitHub Projects □□ □□

| | |
|---|---|
| Field | □ □□ |
| Status | Planned / In Progress / In Review / Needs Rework / Verified / Reported |
| Surface | UAC / DLL / ACL / Service / IPC / Installer / Updater / Persistence |
| Asset | `Updater.exe`, `ServiceA`, `MainUI.dll` |
| Evidence Ready | Yes / No |
| Reviewer | □□□ □□ agent |
| Severity | Info / Low / Medium / High / Critical |
| Run ID | `20260424-001` |

# 7. [illegible]

# □□ □□

□□□□□□□ □ □□ □□ □□□□ □□□□.

## □□□ □□

- UAC / privilege
- DLL loading
- service / IPC
- ACL
- installer / updater
- signing / supply chain
- logging / privacy

## □□ □□

- main executable
- updater
- installer
- service binary
- helper process
- plugin folder
- registry key
- named pipe

# □□□ □□ □□

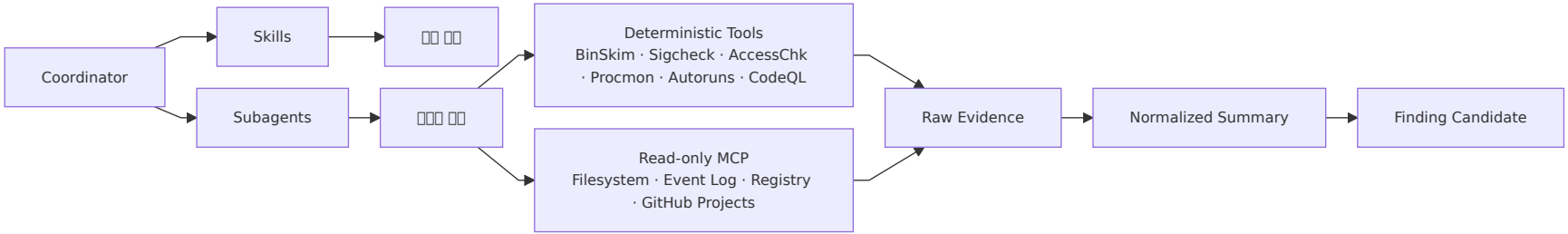
```
[Checklist Item]
ID: WIN-DLL-001
Asset: Updater.exe
Hypothesis: Updater.exe□ □□□ □□ □□ □□□□ DLL□ □□□ □ □□.
Method: Procmon + static import/path review
Evidence:
  - raw: docs/evidence/<run-id>/raw/procmon-updater.pml
  - normalized: docs/evidence/<run-id>/normalized/dll-loads.csv
Auditor Result: FAIL candidate
Reviewer Result: Pending
Verifier Result: Pending
Final Status: In Review
```

# □□ □□ □□

1. □□ 1□□ □□
2. □□□ □□ □□
3. raw evidence □□
4. normalized summary □□
5. Auditor candidate □□
6. Reviewer□ □□ □□
7. Verifier□ □□ □□
8. Coordinator□ □□ □□
9. Verified □□□ □□□□ □□

# 8. □□ · MCP □□

# □□ □□ □□


Coordinator
Skills
□□ □□
Subagents
□□□ □□
Deterministic Tools
BinSkim · Sigcheck · AccessChk
· Procmon · Autoruns · CodeQL
Read-only MCP
Filesystem · Event Log · Registry
· GitHub Projects
Raw Evidence
Normalized Summary
Finding Candidate

# Windows □□ □□ □□

| □□ | □□ | □□ |
|---|---|---|
| Binary hardening | BinSkim | ASLR/DEP/CFG □ □□□·□□ □□ □□ □□ |
| Signing | Sigcheck | Authenticode, timestamp, certificate chain □□ |
| ACL / □□ | AccessChk | □□, □□□□□, □□□, □□□□ □□ □□ |
| Runtime behavior | Procmon | □□, □□□□□, □□□□, □□□ □□ □□ |
| Persistence | Autoruns | □□ □□ □□, □□□, scheduled task □ □□ |
| Source analysis | CodeQL | □□ □□ □□□ variant □□ |

# MCP □□ □□

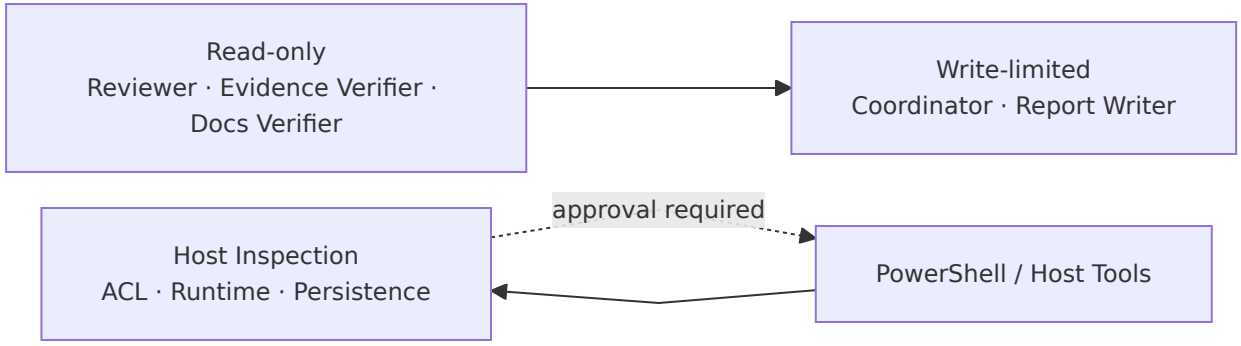
- □□□ read-only
- allowlist □□ tool exposure
- □□□ PowerShell□ □□ □□
- code editing agent□ host inspection MCP □□
- tool call audit log □□
- raw output□ LLM □□ □□
- □□ □□□□□ □□ VM □□

# 9. □□□□□ MCP □□ □□

# □□ □□

| □□ | □□ | □□ |
|---|---|---|
| Prompt injection | □□ □□□ □□□ agent□ □□ □□□ □□ | tool result□ □□□□ □□□□ □□ |
| Tool misuse | □□□□□ □□□ □□□ □□□ □□ | read-only allowlist, approval gate |
| Evidence contamination | raw evidence□ □□□ □□□ | raw/normalized □□ |
| False positive | LLM□ □□□□ □□□ □□ | reviewer/verifier □□ □□□ |
| Exfiltration | □□ □□□□ □□□ □□ | path allowlist, network □□ |
| Irreversible action | □□, □□, □□□□ □□□ □□ | □□ VM, snapshot, explicit approval |

# □□ □□




Reviewer□ Verifier□ □□□ □ read-only□ □□□□□. □□□ □□□ □□ □□ agent□□ □□□□□ □□□□□.

# 10. □□□ □□□ □□

# Evidence Bundle □□

```
docs/evidence/<run-id>/
├─ raw/
│  ├─ binskim.sarif
│  ├─ sigcheck.txt
│  ├─ accesschk.txt
│  ├─ procmon.pml
│  ├─ autoruns.csv
│  └─ eventlog.evtx
├─ normalized/
│  ├─ inventory.csv
│  ├─ binary-hardening.csv
│  ├─ signing-status.csv
│  ├─ acl-summary.csv
│  └─ runtime-observations.md
└─ screenshots/
```

# Finding □□□ □□

```
# F-001: □□□ □□ □□ □□ □□ DLL □□ □□

## □□
Verified

## □□
Updater.exe v1.2.3

## □□
Updater.exe□ □□ □□□ □□ □□ □□□□ DLL□ □□□□.

## □□
□□ □□ □□ □□ □ □□□ □□ □□□

## □□ □□
1. □□ □□□□ □□
2. □□ □□□ □□□ DLL □□
3. Procmon□□ DLL load □□

## □□
- raw: docs/evidence/<run-id>/raw/procmon-updater.pml
- normalized: docs/evidence/<run-id>/normalized/dll-loads.csv

## □□ □□
```

# □□□ □□ □□

- Verified finding□ □□□ □□
- Draft□ Evidence Gap□ □□ □□
- □□ □□□ □□ □□ □□
- □ finding□ evidence path □□
- □□ blocker□ □□ □□ □□□
- □□ □□□ □□□ □□ □□ □□

# 11. [illegible]

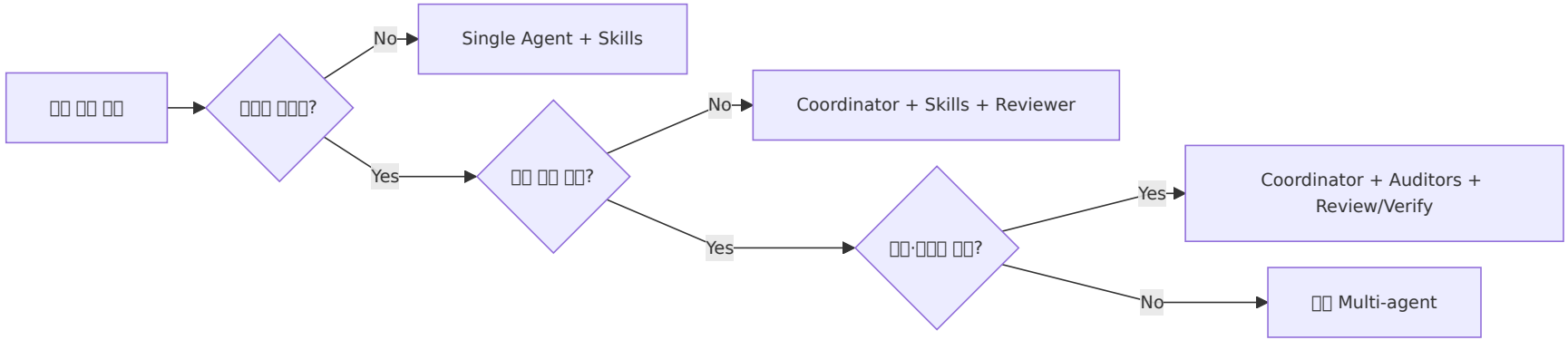
# □□ □□□ □□ □ □□ □□

- □□ □□□ □□
- installer / updater / service / IPC / ACL / runtime□ □□ □□□
- □□ □□ □□□ □□
- □□ □□□ □□ □□□ □□□
- GitHub □□ □□□ □□□
- □□□□□ □□ □□□ □□□□□□ □□□□ □□□ □ □□

# □□ □□

| □□ | □ □□ □□ | □□ |
| --- | --- | --- |
| Single agent + skills + reviewer | □□□ □□ □□□□ □□ | □□□ □□□□□ □□□□ □□□ □□ |
| Custom workflow / orchestrator-worker | □□·□□□ □□□□□ □□□ | □□□ □□□□ □□□ □□ |
| Repo-centric scanner □□ | □□ □□□ □□ □□□ □□□ □□ | runtime/host inspection □□□□□ □□ |
| Full multi-agent | □□ □□□ □□ □□□□ □□□ □□□ | □□, □□, □□ □□□□ □□ |

# □□ □□ □□


□□ □□ □□
□□□ □□□?
No
Single Agent + Skills
Yes
□□ □□ □□?
No
Coordinator + Skills + Reviewer
Yes
□□·□□□ □□?
Yes
Coordinator + Auditors + Review/Verify
No
□□ Multi-agent

# 12. □□□ □□□□ □□

# Coordinator: □□ □□□□

```
□□ □□□□ □□□ □□ □□□□ □□□□ □□□□□□□.
Project Mapper□ Binary Inventory□ □□□ □□, □□□□, □□□, updater,
installer, scheduled task, COM, IPC □□□ □□□□□□.

□ □□ trust boundary□ □□□□,
□□□□□□ □□□/□□□□ □□□□ □□□□□□□.

□□ □□□ □□□□□.
□□□□ docs/status, docs/scope, docs/plans□ □□□□□□□.
```

# Auditor: □□ □□□□

```
□□□ □□□ □□□□□□□.
□ □□□ □□ 1□□□□ □□□□,
raw evidence□ □□ □□□ □ normalized summary□ □□□□□□□.

□□□ candidate □□□□ □□□□□.
Reviewer□ Verifier□ □□□ □ □□□
□□ □□, □□, □□, □□, □□, □□, □□ □□□ □□□ □□□□□.

□□ □□□ □□ □□□□.
```

# Reviewer: □□ □□□□

```
Auditor□ finding candidate□ □□ □□□□ □□□□□□□.
□□ □□, □□ □□□, severity, remediation□ □□□□□□ □□□□□□□.
false positive □□□□ □□□ Needs Rework□ □□□□□□□.

□□ □□□ □□□□□□□ □□□ □□□ □□□ □□□□ □□□□□□□.
```

# Verifier: □□ □□□□

```
Finding candidate□ □□□ □□□ □□ □□□□□ □□□□□□□.
raw evidence, normalized summary, □□, □□, □□ □□ □□,
□□ □□□ □□□□□ □□ □□ □□□□ □□□□□□□.

□□□ □□□□ Evidence Gap□□ □□□□□□□.
severity □□□ Reviewer□□ □□□□□□.
```

# Report Writer: □□ □□□□

```
Verified finding□ □□□ □□□□ □□□□□□.
Draft, Needs Rework, Evidence Gap □□□ □□□ □□ □□ □□ □□□□ □□□□□□.

□□□□□ □□ □□, □□ □□, □□ □□, □□ □□,
□□ blocker, □□ □□□ □□□□□□.
```

# 13. □□ □□□

# 1□□: □□·□□ □□ □□

- `AGENTS.md` □□
- `docs/` □□ □□
- □□ □□□□□ □□
- finding / report □□□ □□
- GitHub Projects □□ □□
- run-id □□ □□

# 2□□: □□·□□ □□ □□

- BinSkim / Sigcheck / AccessChk / Procmon / Autoruns □□ □□
- raw / normalized evidence □□ □□ □□
- inventory □□ □□□□ □□
- read-only MCP allowlist □□
- □□□□ VM □□□ □□ □□ □□

# 3□□: Subagent □□□ □□

- Coordinator □□ □□□
- Auditor□ □□ □□ □□
- Reviewer / Verifier read-only □□
- finding candidate → verified □□ □□□
- false positive □□ □□□□ □□□

# 4□□: □□□ □□ □□

- □□ □□ □□□ □□
- □□ □□ □□□ □□
- evidence bundle □□
- □□ □□ □□
- □□□□□□ skill □□□□

# 14. □□ □□

# □□·□□□□ □□ □□ □□

- OpenAI Codex Best Practices
  https://developers.openai.com/codex/learn/best-practices
- OpenAI AGENTS.md Guide
  https://developers.openai.com/codex/guides/agents-md
- OpenAI Codex Skills
  https://developers.openai.com/codex/skills
- OpenAI Codex Subagents
  https://developers.openai.com/codex/subagents
- OpenAI Agent Approvals & Security
  https://developers.openai.com/codex/agent-approvals-security
- OpenAI PLANS.md / execution plans
  https://developers.openai.com/cookbook/articles/codex_exec_plans
- Anthropic, Building Effective Agents
  https://www.anthropic.com/engineering/building-effective-agents

# GitHub·MCP·□□ □□ □□ □□

- GitHub Copilot Agent Skills
  https://docs.github.com/en/copilot/concepts/agents/about-agent-skills
- GitHub Repository Custom Instructions
  https://docs.github.com/en/copilot/how-tos/copilot-on-github/customize-copilot/add-custom-instructions/add-repository-instructions
- GitHub MCP Integration
  https://docs.github.com/en/copilot/how-tos/copilot-on-github/customize-copilot/customize-cloud-agent/extend-cloud-agent-with-mcp
- GitHub tasklists / sub-issues / issue dependencies
  https://docs.github.com/en/get-started/writing-on-github/working-with-advanced-formatting/about-tasklists
- MCP Tools Specification
  https://modelcontextprotocol.io/specification/2025-11-25/server/tools
- MCP Security Best Practices
  https://modelcontextprotocol.io/docs/tutorials/security/security_best_practices

# □□ □□·Windows □□ □□ □□

- NIST SP 800-218 SSDF

  https://csrc.nist.gov/pubs/sp/800/218/final
- Microsoft Security Development Lifecycle

  https://learn.microsoft.com/en-us/compliance/assurance/assurance-microsoft-security-development-lifecycle
- Microsoft Threat Modeling Tool

  https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool
- BinSkim

  https://learn.microsoft.com/en-us/windows-hardware/drivers/driversecurity/binskim-check-binaries
- AccessChk

  https://learn.microsoft.com/en-us/sysinternals/downloads/accesschk
- Process Monitor

  https://learn.microsoft.com/en-us/sysinternals/downloads/procmon
- Autoruns

  https://learn.microsoft.com/en-us/sysinternals/downloads/autoruns

# Slidev □□ □□ □□

- Slidev Syntax Guide

  https://sli.dev/guide/syntax
- Slidev Importing Slides

  https://sli.dev/features/importing-slides
- Slidev Why / Markdown-based

  https://sli.dev/guide/why